



DATA SECURITY ADDENDUM (DSA)

Document Classification: Enterprise Legal Compliance Standard & Data Privacy Attestation

System Target: AegisVault — Enterprise Security Questionnaire Engine (v1.0-PRO)

Regulatory Alignment: SOC 2 Type II, ISO/IEC 27001:2022, GDPR, CCPA

1. Scope of Data Processing & Architectural Boundaries

- **Localized Infrastructure Execution:** The AegisVault workflow engine executes entirely within the customer's self-hosted, cloud-hosted, or dedicated n8n automation workspace. No inbound questionnaire data or internal policy documentation passes through vendor-owned intermediary servers or third-party data brokers.
- **Data Minimization Enforced:** The system ingests only necessary security documents and compliance questionnaires required to fulfill audit obligations. All processed data is categorized strictly under corporate technical compliance data.

2. Artificial Intelligence & Zero Model Training Guarantee

- **Enterprise API Privacy Assurance:** AI evaluation (Node 15) utilizes official Google Cloud Gemini Enterprise API endpoints (models/gemini-2.0-flash / models/gemini-1.5-pro). Under Google Cloud Enterprise Terms of Service, data submitted via paid enterprise API endpoints is strictly isolated and **is never retained, logged for human review, or utilized to train, fine-tune, or improve foundational LLM models.**
- **No Consumer Prompts:** The system strictly prohibits the use of free-tier consumer web interfaces (e.g., public ChatGPT or web-based Gemini chat apps) for processing corporate data payloads.

3. Ephemeral In-Memory Processing & Storage Lifecycle

- **Volatile Memory Aggregation:** Internal policy documents parsed by Zone 1 (Nodes 2–7) are held in temporary execution memory as plaintext

(Master_Ground_Truth). This data exists strictly for the duration of the active execution loop and is purged immediately upon completion of the questionnaire batch.

- **Automated Data Archiving:** Upon completion of processing, Node 20 automatically relocates the original source questionnaire from the active queue to an isolated customer archive folder (Completed_Questionnaire).

4. Cryptographic Standards & Access Governance

- **Encryption in Transit & at Rest:** All data exchanges between the n8n orchestration engine, Google Workspace storage, and Google Gemini API endpoints are encrypted in transit using Transport Layer Security (TLS 1.3). Data stored within Google Drive and Google Sheets is encrypted at rest using Advanced Encryption Standard with 256-bit keys (AES-256).
- **Scoped Least-Privilege OAuth 2.0:** System connectivity requires dedicated OAuth 2.0 authentication tokens scoped strictly to read designated policy folders and append data to designated dashboard worksheets.
- **Credential Vaulting:** All API keys, client secrets, and access tokens are vaulted securely within the customer's native n8n encrypted credential store.

5. Human-In-The-Loop (HITL) & Risk Containment

Controls

- **Deterministic Verification Gate:** To eliminate AI hallucination liabilities, Node 16 evaluates the structured output against a deterministic confidence rule.
- **Quarantine of Unsupported Claims:** Any question that cannot be answered using verbatim text from the internal Master_Ground_Truth is tagged as Knowledge_Match: "Missing" and quarantined in the Review_Required worksheet. Automated systems are strictly prohibited from generating speculative or unverified compliance claims.

6. Incident Response, Audit Trails & Breach Notification

- **Immutable Audit Logging:** In accordance with SOC 2 Type II logging requirements, Nodes 18 and 18b automatically capture system exceptions, rate limits, and failed payloads, writing immutable records (Timestamp, Execution ID, Failed Node, Error Message) directly to the System Audit dashboard.
- **Breach Notification SLA:** In the event of a confirmed security incident impacting customer data payloads or API credentials, the customer commits to initiating incident response protocols within twenty-four (24) hours of verification.
- **Audit Rights:** Customers maintain full administrative rights to audit workflow logs, execution histories, and data routing paths at any time via their native n8n instance dashboard.